

Audit de robustesse des mots de passe

Matisse

Kra

Sommaire

Contexte :	2
Étape 1 : Préparation de l'environnement Windows 10	2
Étape 2 : Configuration de l'environnement d'attaque (Kali Linux)	2
Étape 3 : Tests de robustesse avec John the Ripper (JtR)	3
1. Attaque "Single Crack" (Mode simple)	3
2. Attaque par Dictionnaire (Wordlist)	3
3. Attaque par Force Brute (Incremental)	3
Étape 4 : Utilisation des Rainbow Tables avec Ophcrack	4
Conclusion et Préconisations	4

Contexte :

À la demande de M. Brillat, j'ai réalisé un audit de sécurité visant à tester la robustesse des identifiants de connexion des partenaires. L'objectif était de simuler une usurpation pour vérifier l'efficacité de la sensibilisation des utilisateurs.

Environnement technique :

- Une machine virtuelle (VM) Windows 10.
- Une distribution Kali Linux en "Live CD" (fichier ISO).
- Outils : fgdump, John the Ripper, Ophcrack.

Étape 1 : Préparation de l'environnement Windows 10

En premier, je me suis occupé à paramétrer la machine Windows 10 pour simuler des comptes utilisateur vulnérables

1. **Création des comptes** : Connecté en tant qu'administrateur, j'ai créé trois comptes utilisateurs locaux:
 - ENEDIS : Mot de passe faible (< 8 caractères alphanumériques), ex : judo63.
 - MSA : Mot de passe plus robuste (> 8 caractères), ex : aurillac15.
 - CLIC : Mot de passe au choix.
2. **Extraction des hachages (Hashes)** :
 - J'ai désactivé la protection en temps réel et le contrôle des applications pour permettre l'exécution des outils d'audit.
 - J'ai exécuté l'outil FGDUMP en mode administrateur. Cela a permis d'extraire les contenus des fichiers système SYSTEM et SAM vers un fichier nommé 127.0.0.1.pwdump.
 - À l'aide de Notepad++, j'ai nettoyé le fichier pour ne conserver que les lignes concernant les utilisateurs ENEDIS, MSA et CLIC.
3. **Récupération des tables** : J'ai téléchargé et décompressé le fichier vista_proba_free.zip (tables arc-en-ciel) sur le bureau pour l'utiliser plus tard.

Étape 2 : Configuration de l'environnement d'attaque (Kali Linux)

J'ai redémarré la machine virtuelle en bootant sur l'image ISO de Kali Linux, sans installer l'OS, pour travailler en "Live".

1. **Configuration du clavier** : Passage du clavier en AZERTY via la commande :
setxkbmap fr.
2. **Repérage et accès au disque Windows** :
 - J'ai utilisé la commande fdisk -l pour lister les partitions. J'ai identifié la partition Windows (généralement la plus volumineuse, type sda ou nvme).

```
root@kali:~# fdisk -l
Disk /dev/sda: 50 GiB, 53687091200 bytes, 104857600 sectors
Units: sectors of 1 * 512 = 512 bytes
Sector size (logical/physical): 512 bytes / 512 bytes

Device      Boot      Start         End      Sectors   Size Id Type
/dev/sda1   * 2048       104447       102400        50M   7 HPFS/NTFS/exFAT
/dev/sda2                104448  104855551  104751104  49.9G   7 HPFS/NTFS/exFAT
```

- J'ai navigué dans les dossiers pour retrouver le fichier d'extraction généré sous Windows.
- Chemin identifié :
/media/kali/[UUID_Partition]/Users/Admin/Desktop/127.0.0.1.pwdump.

Étape 3 : Tests de robustesse avec John the Ripper (JtR)

J'ai utilisé l'outil John the Ripper pour tenter de casser les mots de passe extraits, en utilisant différentes méthodes d'attaque. Pour chaque commande, j'ai spécifié le format NT (--format=NT).

1. Attaque "Single Crack" (Mode simple)

Ce mode tente de deviner le mot de passe à partir du nom d'utilisateur (ex: enedis12, Enedis!).

- **Commande** : john --single /chemin/vers/127.0.0.1.pwdump.
- **Observation** : Cette méthode est très rapide pour les mots de passe basiques liés au login.

2. Attaque par Dictionnaire (Wordlist)

J'ai testé des dictionnaires de mots de passe courants.

- **Dictionnaire par défaut** : Utilisation de password.lst via la commande john --wordlist /chemin/vers/fichier.
- **Dictionnaire Rockyou** : J'ai décompressé le célèbre dictionnaire rockyou.txt.gz situé dans /usr/share/wordlists/ avec gunzip pour lancer une attaque plus massive.
- **Dictionnaire personnalisé** : J'ai édité le fichier password.lst avec nano pour y ajouter des variantes logiques (ex: lieu + nom + chiffre comme mspMsa2) afin de vérifier si des habitudes de création de mots de passe prévisibles pouvaient être exploitées.

3. Attaque par Force Brute (Incremental)

Pour les mots de passe non trouvés précédemment, j'ai lancé une attaque exhaustive testant toutes les combinaisons.

- **Commande** : john --incremental /chemin/vers/fichier.
- **Résultat** : J'ai utilisé la commande john --show ... pour afficher les mots de passe finalement cassés.

```
root@kali:~# john --format=NT 127.0.0.1.pwdump
Using default input encoding: UTF-8
Loaded 3 password hashes with no different salts (NT [MD4 128/128 AVX 512BW])
Press 'q' or Ctrl-C to abort, almost any other key for status
judo63          (ENEDIS)
aurillac15      (MSA)
123456          (CLIC)
3g 0:00:00:00 DONE (2025-12-11 14:22) 33.33g/s 11460p/s 11460c/s 11460C/s
Use the "--show --format=NT" option to display all of the cracked passwords reli
```

Étape 4 : Utilisation des Rainbow Tables avec Ophcrack

En seconde phase, j'ai utilisé une approche différente basée sur les tables arc-en-ciel (compromis temps/mémoire).

1. J'ai lancé l'outil graphique Ophcrack.
2. J'ai cliqué sur Load puis chargé le fichier 127.0.0.1.pwdump contenant les hashes.
3. J'ai cliqué sur Tables puis Install pour charger le dossier vista_proba_free préparé à l'étape 1.
4. J'ai lancé l'attaque en cliquant sur Crack.

```
root@kali:~# john --show --format=NT 127.0.0.1.pwdump
ENEDIS:judo63:500:NO PASSWORD*****:
MSA:aurillac15:501:NO PASSWORD*****:
CLIC:123456:502:NO PASSWORD*****:

3 password hashes cracked, 0 left
```

Observation : Cette méthode est extrêmement rapide pour les mots de passe alphanumériques standards couverts par la table, mais échoue si le mot de passe est trop long ou contient des caractères non inclus dans la table utilisée.

Conclusion et Préconisations

Suite à ces tests, nous avons pu constater que les mots de passe courts (comme ENEDIS) ou basés sur le dictionnaire sont découverts quasi-instantanément.

Critères pour améliorer la sécurité des mots de passe:

1. Longueur : Imposer un minimum de 12 caractères (les attaques brute-force deviennent exponentiellement plus longues).
2. Complexité : Mélanger majuscules, minuscules, chiffres et caractères spéciaux (pour contrer les attaques par dictionnaire simple et tables arc-en-ciel basiques).
3. Aléatoire : Éviter les mots du dictionnaire ou les données personnelles (Nom, Ville, Date) qui sont vulnérables aux règles de mutation de John the Ripper.

matisse kra
bts sio - Gap